

SIMATS ENGINEERING

ASSESSMENT TOOL 3

Name	SHAIK REEHAN
Register Number	192565071
Date	
Time	1hr

COURSE NAME: Cybersecurity Incident Handling And Response

COURSE CODE: CSA60

COURSE OUTCOME COVERED

CO4: Appraise containment, eradication, recovery strategies by selecting appropriate techniques such as isolation, malware removal, patch management, system restoration to ensure secure operations. (BL3, BL4)

Activity Tool : System Recovery and Backup Validation (Low)

Assessment Tool Weightage: 10%

Code of Conduct:

I _____shaikreehan.192565071_____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Shaik Reehan

RUBRICS FOR CALCULATION:

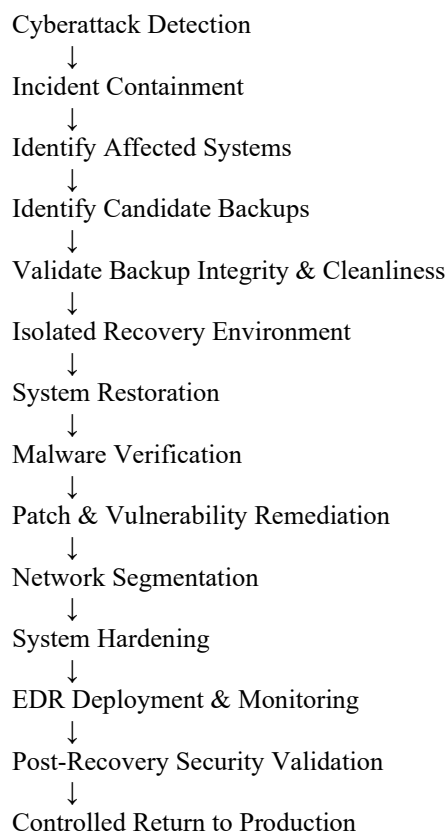
Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Backup Identification and Validation	25%	Accurately identifies appropriate backups and thoroughly validates their integrity, completeness, availability, and freedom from malware before restoration.	Identifies and validates suitable backups with minor omissions.	Performs basic backup validation but misses important integrity or security checks.	Unable to identify or validate an appropriate backup.
System Restoration and Recovery	25%	Successfully restores systems and data using trusted backups while maintaining data integrity and following a secure recovery process.	Restores systems and data correctly with minor errors or omissions.	Performs basic restoration but encounters issues with data integrity or recovery procedures.	Unable to successfully restore the affected systems or data.
Recovery Security and Hardening	20%	Effectively applies patches, secure configurations, access controls, network segmentation, and other security measures before returning systems to operation.	Applies appropriate security controls with minor gaps.	Implements basic security measures but leaves some weaknesses unresolved.	Fails to apply appropriate security controls during recovery.
Post-Recovery Validation and Monitoring	15%	Thoroughly validates system integrity, malware removal, vulnerabilities, configurations, and connectivity and establishes continuous monitoring after recovery.	Performs appropriate validation and monitoring with minor omissions.	Performs basic validation but misses important security or monitoring checks.	Unable to properly validate or monitor the recovered systems.
Documentation and Recovery Report	15%	Provides clear, professional documentation covering backup validation, restoration steps, security checks, recovery results, evidence, and recommendations.	Documentation is well organized and includes most required recovery details.	Documentation is partially organized with limited evidence or recovery details.	Documentation is incomplete, poorly organized, and lacks supporting evidence.

1. Comprehensive System Recovery and Backup Validation

Introduction

When a financial organization suffers a cyberattack affecting database servers and employee endpoints, recovery must be performed carefully to prevent reinfection and data loss. The recovery process should not simply restore the latest backup. The organization must first contain the attack, identify trusted backups, validate their integrity and security, restore systems in a controlled environment, apply patches and hardening, and continuously monitor the recovered infrastructure.

The complete recovery process is:



1. Incident Containment

The first step is to stop the attack from causing additional damage.

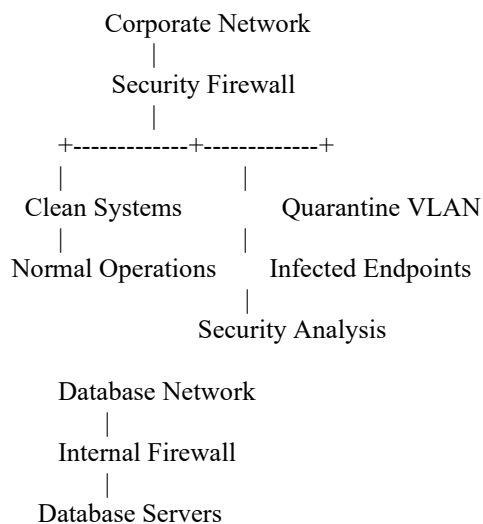
The security team should:

1. Isolate compromised database servers.
2. Isolate infected employee endpoints.
3. Place suspicious endpoints into a quarantine VLAN.

4. Disable compromised accounts.
5. Block malicious IP addresses and domains.
6. Restrict unnecessary internal communication.
7. Block suspicious ports and protocols.
8. Preserve important logs and forensic evidence.
9. Identify indicators of compromise (IOCs).
10. Determine the scope of the attack.

The goal is to prevent attackers or malware from moving laterally while the recovery process is prepared.

Example



Critical database servers should not communicate freely with employee endpoints.

2. Identify and Select a Trusted Backup

The organization should identify all available backups before selecting one for recovery.

Potential backup sources include:

- Full backups
- Incremental backups
- Differential backups
- Offline backups
- Immutable backups
- Off-site backups
- Cloud backups
- Replicated backup systems

The backup should be selected based on:

- Date and time
- Completeness
- Business requirements
- Recovery Point Objective (RPO)
- Recovery Time Objective (RTO)
- Known malware activity
- Backup integrity
- Availability of required data

The most recent backup should **not automatically be selected** if it may have been created after the attacker gained access.

A trusted backup should ideally come from a point in time **before the compromise**.

3. Backup Integrity and Security Validation

Before restoring anything, the backup must be validated.

A. Check Backup Metadata

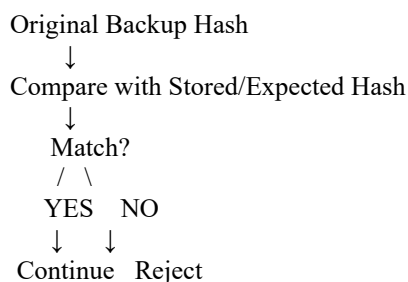
Verify:

- Backup date and time
- Backup type
- Backup size
- Source system
- Backup job status
- Backup completion status
- Retention information

B. Verify Integrity

Use available backup-system integrity checks and cryptographic hashes where appropriate.

For example:



A mismatch may indicate corruption or unauthorized modification.

C. Verify Completeness

Confirm that the backup contains:

- Required databases
- Required files
- Application data
- Configuration data
- Necessary system information
- Required permissions and metadata

D. Verify Backup Cleanliness

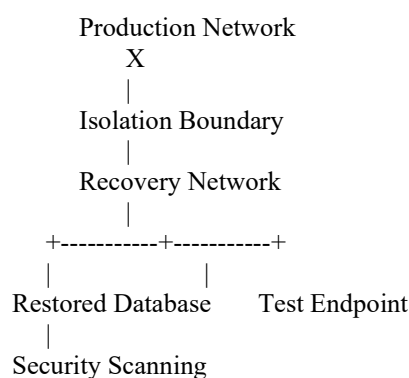
The backup should be scanned and examined for:

- Malware
- Suspicious executables
- Malicious scripts
- Ransomware artifacts
- Known IOCs
- Unauthorized modifications

The backup should be restored into an **isolated recovery environment first**, rather than directly into production.

4. Isolated Recovery Environment

A separate recovery environment should be created.



The recovery environment should have restricted connectivity.

This prevents a potentially infected backup from spreading malware into the production environment.

5. System Restoration

Once the backup has passed validation, restoration can begin.

Database Servers

1. Prepare clean operating systems or known-good images.
2. Apply required security updates where appropriate.
3. Restore the database software.
4. Restore database data.
5. Restore required configurations.
6. Verify database consistency.
7. Test database services.
8. Verify application connectivity.

Employee Endpoints

Compromised endpoints should preferably be **reimaged from trusted sources** rather than simply restoring potentially compromised system files.

After reimaging:

- Apply security patches.
- Install EDR.
- Configure security policies.
- Restore only required user data.
- Reset potentially compromised credentials.

6. Malware Verification

After restoration, the organization must verify that malware has not returned.

Security checks should include:

- Full EDR scan
- Antivirus scan
- IOC searches
- Process inspection
- Startup/persistence inspection
- Scheduled-task inspection
- Service inspection
- Network connection analysis
- Authentication-log review

The security team should specifically search for the indicators associated with the original attack.

If malware or suspicious persistence is detected, the system should remain isolated and undergo further investigation or reimaging.

7. Patch Management and Vulnerability Remediation

The original attack should be analyzed to determine how the attacker gained access.

If an unpatched vulnerability was exploited:

1. Identify the vulnerability.
2. Identify all affected systems.
3. Determine severity and exploitability.
4. Obtain the appropriate security patch.
5. Test the patch.
6. Deploy it in stages.
7. Verify installation.
8. Perform a vulnerability scan.

Priority should be given to:

Actively Exploited Critical Vulnerabilities
↓
Internet-Facing Critical Systems
↓
High-Risk Vulnerabilities
↓
Medium-Risk Vulnerabilities
↓
Low-Risk Vulnerabilities

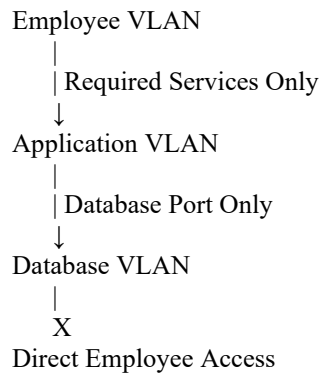
8. Network Segmentation

Network segmentation should be implemented or strengthened before production recovery.

A financial organization can separate:

- Employee VLAN
- Application VLAN
- Database VLAN
- Management VLAN
- Backup VLAN
- Security/Monitoring VLAN
- Guest VLAN

Example:



Firewall and ACL rules should follow the **least-privilege principle**.

Only required traffic should be allowed between segments.

The backup network should also be protected from normal user networks so attackers cannot easily compromise backup infrastructure.

9. System Hardening

Before returning systems to production, hardening should be performed.

Operating System

- Apply security patches.
- Disable unnecessary services.
- Remove unnecessary software.
- Close unused ports.
- Enable host firewalls.
- Enable secure logging.
- Disable insecure protocols where possible.

Account Security

- Remove unauthorized accounts.
- Apply least privilege.
- Review administrator accounts.
- Reset compromised credentials.
- Enable MFA for privileged access.
- Secure service accounts.

Database Security

- Restrict database access.

- Remove unnecessary database accounts.
- Apply least privilege.
- Encrypt sensitive information where required.
- Enable database auditing.
- Restrict administrative interfaces.

Network Security

- Apply firewall rules.
- Restrict east-west traffic.
- Separate management traffic.
- Protect backup networks.
- Enable IDS/IPS where appropriate.

10. EDR Monitoring

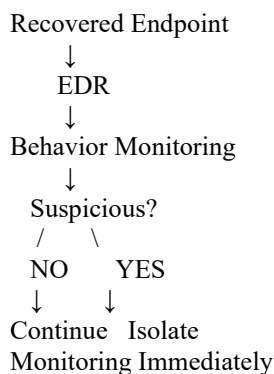
Endpoint Detection and Response should be deployed on supported endpoints and servers.

EDR should monitor:

- Processes
- File activity
- Registry/configuration changes
- Network connections
- Suspicious behavior
- Malware indicators
- Authentication events

Alerts should be forwarded to the SIEM/security team.

For example:



Recovered systems should receive enhanced monitoring during the post-recovery period.

11. Post-Recovery Security Validation

Before returning the organization to normal operations, perform a final validation.

Security Validation

- Malware scan → Clean
- IOC search → No suspicious matches
- Vulnerability scan → Critical issues resolved
- Patch verification → Complete
- Configuration review → Hardened
- Firewall review → Correct
- Account review → No unauthorized accounts
- EDR → Active
- Logging → Working

Functional Validation

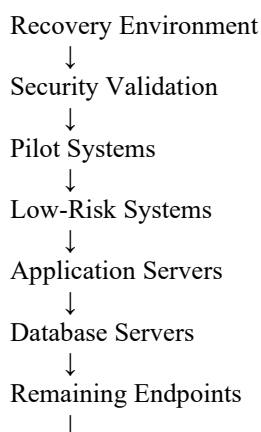
- Database services work correctly.
- Applications can communicate with databases.
- Employee systems can access required resources.
- Authentication works.
- Business transactions function correctly.
- Data is complete and consistent.

Only systems that pass both security and functional validation should be returned to production.

12. Controlled Return to Production

Systems should be restored gradually rather than reconnecting everything simultaneously.

A possible sequence is:



Enhanced monitoring should remain active throughout the process.

13. Documentation and Recovery Report

The recovery report should document:

Incident

- Attack date and time
- Affected systems
- Attack vector
- Malware identified
- Indicators of compromise

Backup

- Backups considered
- Selected backup
- Backup date
- Integrity results
- Malware-scan results
- Completeness results

Restoration

- Restoration procedure
- Systems restored
- Data restored
- Recovery results
- Validation results

Security

- Vulnerabilities discovered
- Patches applied
- Hardening actions
- Firewall changes
- Network segmentation
- EDR deployment

Final Result

- Systems successfully recovered
- Security validation results

- Remaining risks
 - Monitoring status
 - Lessons learned
 - Recommendations
-

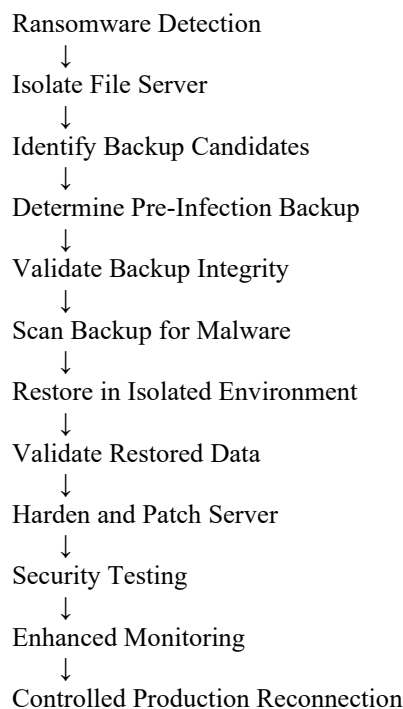
2. Disaster Recovery and Backup Integrity Validation

Scenario

A company's primary file server has been encrypted by ransomware. The organization intends to recover the data using its backup system.

The recovery process must ensure that the selected backup is **trusted, complete, uncorrupted, and free from ransomware or other malicious content** before restoration.

The process is:



1. Isolate the Ransomware-Affected Server

The first action is containment.

The affected server should be:

- Removed from the network.
- Isolated from other file servers.
- Prevented from accessing backup systems.
- Prevented from communicating with employee endpoints.
- Monitored for additional ransomware activity.

The organization should also investigate whether other systems were encrypted.

2. Identify a Trusted Backup

The backup team should examine available backup versions.

For example:

Backup	Date	Status	Decision
Backup A	Before attack	Clean	Preferred
Backup B	Shortly before attack	Unknown	Investigate
Backup C	After encryption	Potentially affected	Reject
Offline Backup	Before attack	Verified	Strong candidate

The preferred backup should be from a **known point before ransomware activity began**.

If possible, use an offline or immutable backup because ransomware may have attempted to modify online backups.

3. Validate Backup Integrity

The selected backup must be checked before restoration.

Verify:

Availability

- Backup can be accessed.
- Required files exist.
- Backup job completed successfully.

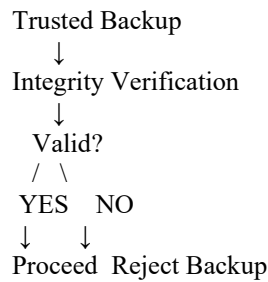
Completeness

Confirm that the backup contains:

- Required directories.
- Business documents.
- File metadata.
- Required permissions.
- Important configuration information.

Integrity

Use the backup system's integrity verification and cryptographic hashes where available.



A corrupted backup should not be used for recovery.

4. Verify the Backup Is Free From Malware

The backup should be examined before restoration.

Security checks should include:

- Malware scanning.
- IOC searches.
- Ransomware artifact detection.
- Suspicious executable detection.
- Suspicious script detection.
- Review of file modification times.
- Review of unusual encryption patterns.

The backup should preferably be restored into an isolated environment first.

5. Restore the Data Safely

The recovery server should be clean and hardened.

The restoration process should be:

1. Build or select a trusted server image.
2. Patch the operating system.
3. Install required security software.
4. Connect only to the isolated recovery environment.
5. Restore the validated backup.
6. Scan restored data.
7. Verify file permissions.
8. Verify file structure.
9. Test sample files.
10. Confirm that files can be opened normally.

Do not immediately overwrite the production server until the recovery copy has passed validation.

6. Test Restored Data Integrity

After restoration, verify that the recovered data is usable.

Tests should include:

File Integrity

- Confirm expected file counts.
- Check file sizes.
- Compare hashes where appropriate.
- Confirm expected directory structure.

Functional Testing

Open representative files from different categories:

- Documents
- Spreadsheets
- PDFs
- Images
- Databases or application files, where applicable

Confirm that files are not corrupted or encrypted.

Permission Testing

Verify:

- Correct owners.
 - Correct groups.
 - Correct access permissions.
 - No unexpected public access.
-

7. Patch and Harden the Recovered Server

Before reconnecting the file server:

Patch

- Apply current security updates.
- Fix the vulnerability used by the ransomware.
- Verify patch installation.
- Run vulnerability scans.

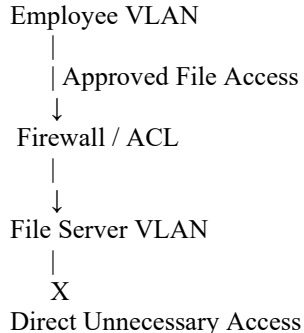
Harden

- Disable unnecessary services.
 - Close unused ports.
 - Enable host firewall.
 - Apply least privilege.
 - Remove unauthorized accounts.
 - Reset compromised credentials.
 - Enable MFA for administrative access where supported.
 - Install and activate EDR.
-

8. Network Segmentation

The recovered file server should be placed in an appropriate server VLAN.

Example:



Only required file-sharing protocols and administrative connections should be allowed.

The backup infrastructure should remain separately protected.

9. EDR and Continuous Monitoring

Before reconnection, EDR should be active.

Monitor for:

- Mass file modifications.
- File encryption behavior.

- Suspicious processes.
- Unexpected scripts.
- Unusual network connections.
- Privilege escalation.
- Unauthorized account activity.

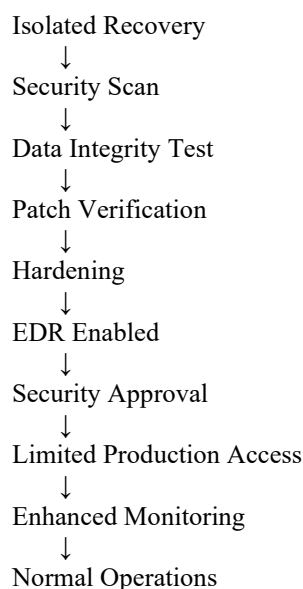
Ransomware-specific detection rules should be enabled where available.

If mass encryption activity begins again, the server should be immediately isolated.

10. Controlled Return to Normal Operations

The server should not immediately return to unrestricted production.

A controlled recovery should be:



Access can initially be limited to a small group of authorized users. After confirming stable operation, normal access can gradually be restored.

11. Post-Recovery Validation

Final validation should confirm:

Validation Area	Expected Result
Backup integrity	Valid

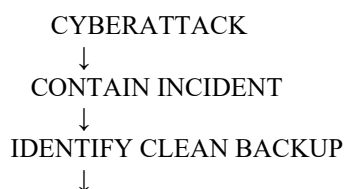
Validation Area	Expected Result
Backup malware scan	Clean
Restored files	Complete
File integrity	Verified
Permissions	Correct
Malware scan	Clean
Vulnerability scan	No critical unresolved issues
Security patches	Current
Firewall	Correctly configured
EDR	Active
Logging	Enabled
Monitoring	Active
Application/file access	Working

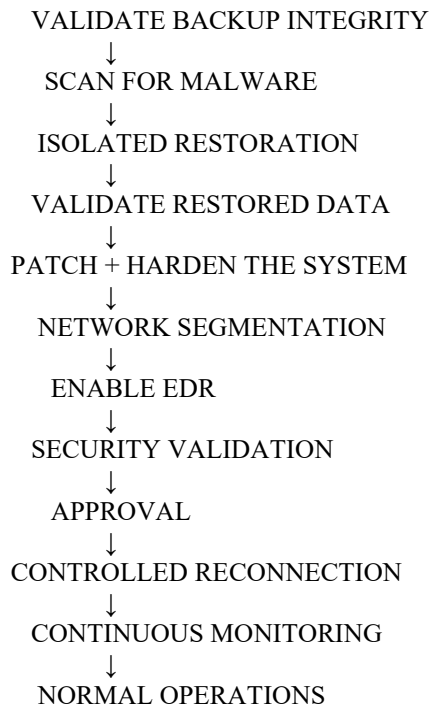
12. Recovery Documentation

The recovery report should contain:

- Ransomware incident timeline.
 - Affected server details.
 - Backup versions considered.
 - Selected backup and reason for selection.
 - Integrity verification results.
 - Malware-scan results.
 - Restoration procedure.
 - Data validation results.
 - Patches applied.
 - Hardening actions.
 - Network changes.
 - EDR configuration.
 - Monitoring results.
 - Approval for production reconnection.
 - Remaining risks.
 - Lessons learned.
-

Final Recovery Model





Conclusion

A reliable disaster-recovery process must treat backups as **security-sensitive recovery assets**, not simply copies of data. The organization should select a backup from a trusted pre-attack point, verify its integrity and completeness, scan it for malware, restore it in an isolated environment, validate the recovered data, patch and harden the server, and enable EDR and continuous monitoring before reconnecting it to production.

For the financial organization, the complete process protects both **database infrastructure and employee endpoints** through containment, trusted-backup recovery, segmentation, hardening, patch management, EDR monitoring, and post-recovery validation. For the ransomware scenario, the same principles ensure that the company does not accidentally restore an infected or corrupted backup and recreate the original attack.